

Contents

NationalBank Reserve — Red Team Capstone	1
Checkpoint 3: Web + API Security Assessment	1
1. Executive Summary	1
2. Methodology	1
3. Web Application Findings (OWASP Top 10)	2

NationalBank Reserve — Red Team Capstone

Checkpoint 3: Web + API Security Assessment

Analyst: Mustafa Musa Ahmed **Date:** 2026 **Classification:** CONFIDENTIAL — Authorized Lab Environment

1. Executive Summary

A comprehensive web application and API security assessment was conducted on the authorized lab environment. The assessment identified 13 vulnerabilities across OWASP Top 10 and API Security Top 10 categories.

Overall Risk Rating: CRITICAL

Key Findings: - 6 Web Application vulnerabilities (OWASP Top 10) - 7 API vulnerabilities (API Security Top 10) - 5 CRITICAL issues allow complete compromise - 5 HIGH severity issues allow data theft / RCE - 3 MEDIUM severity issues weaken defense-in-depth

Business Impact: If this were a production system: - An attacker could extract all customer data via SQL Injection - Execute arbitrary commands on the server (RCE) - Access any user account via BOLA - Bypass authentication entirely - Read internal files via SSRF

2. Methodology

Tool	Purpose
Custom Python scripts (requests, flask)	Automated OWASP + API testing
DVWA v1.10	Intentionally vulnerable web application
Custom Flask API	Intentionally vulnerable API
Manual verification	Confirming each finding

Targets: - Web App: http://localhost (DVWA v1.10) - API: http://localhost:5000 (Custom Flask)

3. Web Application Findings (OWASP Top 10)

A01:2021 - Broken Access Control (CSRF)

CVSS: 8.1 - HIGH

Description: Password change form has no CSRF token. An attacker can craft a malicious page that changes the admin password without consent.

PoC Payload: